

The Incident Response Process

Six stages: a repeatable procedure

Dr. Feras Shahbi

College of Computer Science · King Khalid University



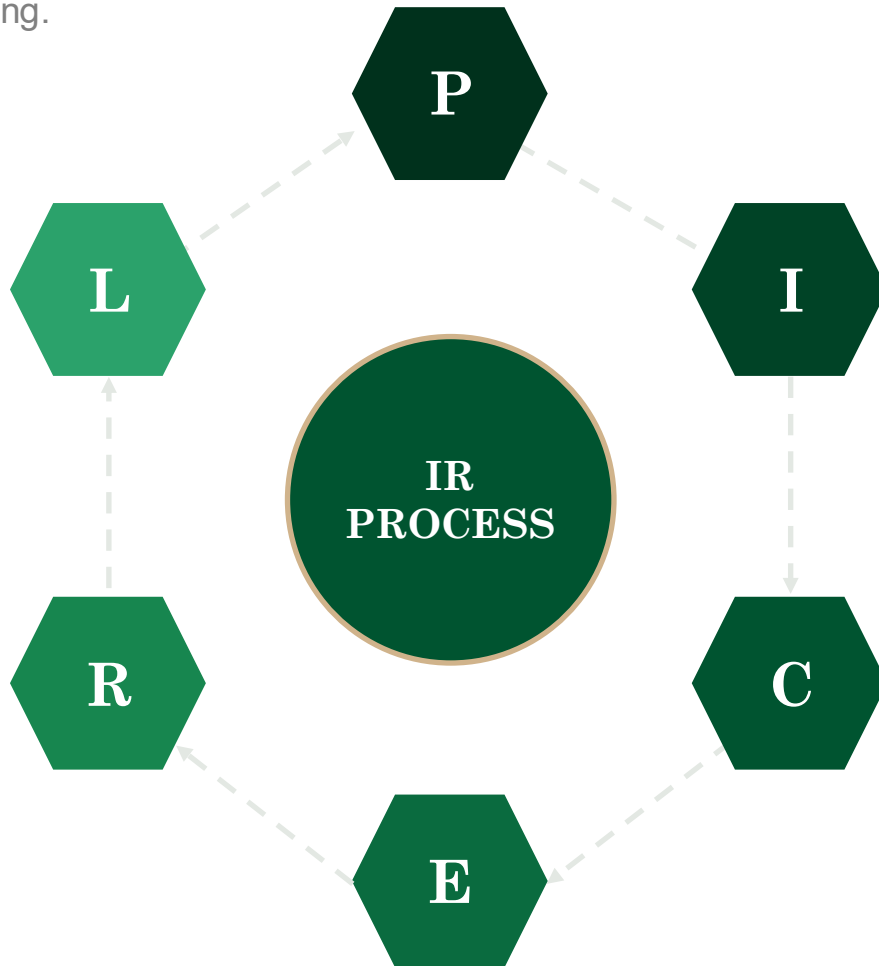
KING KHALID UNIVERSITY

جامعة الملك خالد



One incident, six repeatable stages

Every incident, from a single phished laptop to a company-wide breach, is worked through the same loop. Learn the loop once and you can respond to anything.



P Preparation Get ready before anything happens

I Identification Detect it and confirm what you are facing

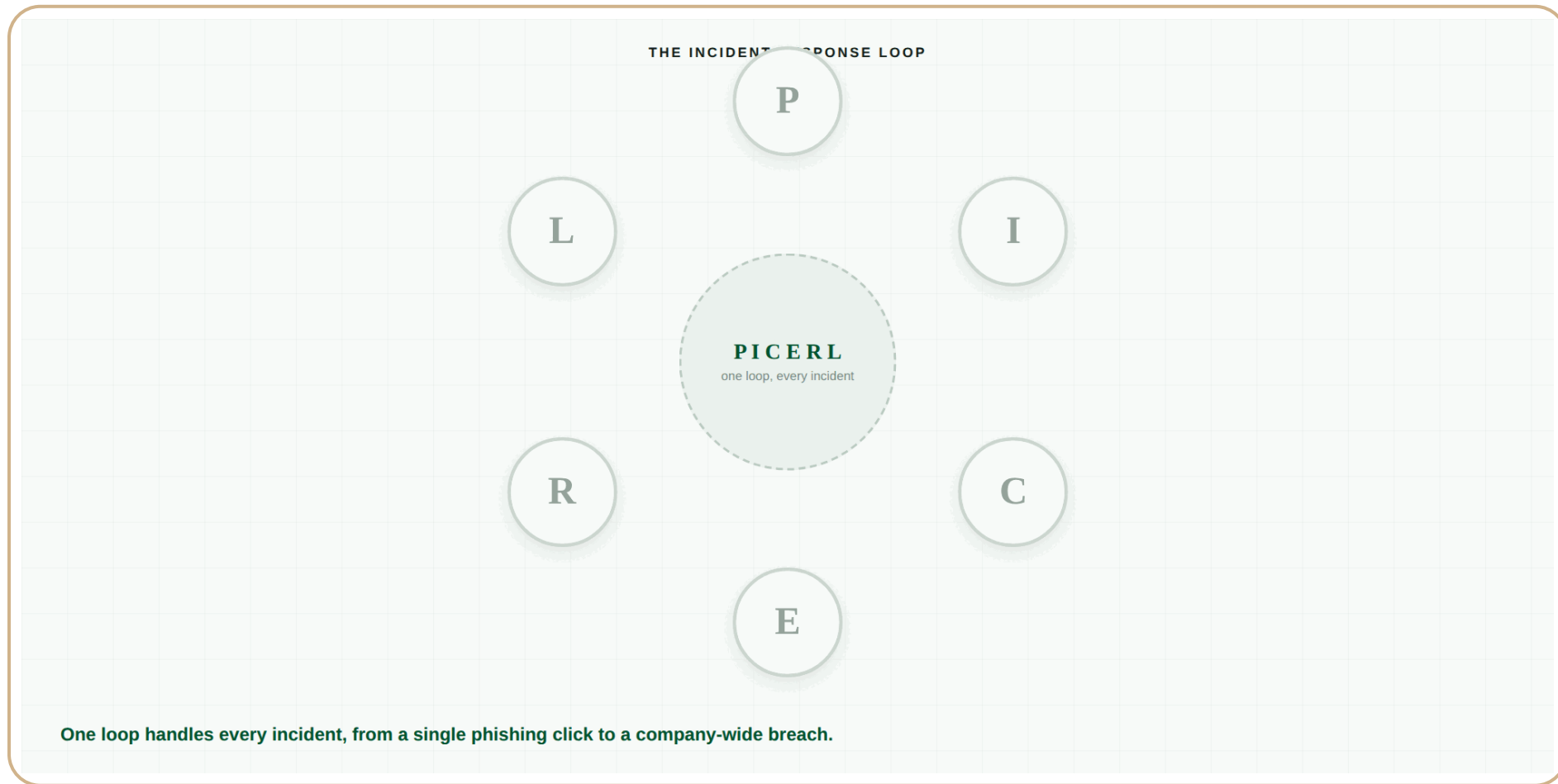
C Containment Stop it from spreading

E Eradication Remove the threat completely

R Recovery Return safely to normal operations

L Lessons Learned Study it so the next one is easier

The response loop, stage by stage



The six PICERL stages light up in order, then the loop closes back to Preparation, a little readier for the next incident.

Two goals, and how the textbook maps on



Investigate

Find out what happened: the malware and tools used, which systems were hit, what the attacker achieved, whether it is ongoing, and the time frame.



Remediate

Use what the investigation found to build and carry out a plan that removes the attacker and prevents a repeat.

Your textbook uses three broad phases. Our six stages simply zoom in on them:

Initial Response

textbook phase

Preparation

Identification

Investigation

textbook phase

Identification

Containment

Remediation

textbook phase

Eradication

Recovery

Lessons Learned

STAGE 1 OF 6



Preparation

The work you do before the alarm ever sounds.

Analogy: smoke detectors, extinguishers and fire drills. You install them when there is no fire, because during the fire there is no time.

P

I

C

E

R

L

P I C E R L



KING KHALID UNIVERSITY

جامعة الملك خالد

Have the team, the plan, and the tools ready



The team

A core investigative team, led by an experienced incident coordinator (often the CISO or CIO), supported by Legal, HR, Compliance, Network, and Business-line managers.

- ✓ Core investigators
- ✓ Legal & HR
- ✓ Compliance
- ✓ Network & IT
- ✓ Business managers



The plan

A written incident response plan with named roles, contacts, and escalation paths, agreed and rehearsed before any real incident.

- ✓ Named roles
- ✓ Contact lists
- ✓ Escalation paths
- ✓ Rehearsed drills
- ✓ Clear authority



The tools

The capability to act: skills in investigations, forensics and network analysis, plus the software and access ready to deploy on day one.

- ✓ Forensic skills
- ✓ Network analysis
- ✓ IoC utilities
- ✓ Ready access
- ✓ Log collection

STAGE 2 OF 6



Identification

Detect the incident, then confirm exactly what you are dealing with.

Analogy: diagnosis. Symptoms appear, you run tests, and you name the disease and how far it has spread before you treat anything.

P

I

C

E

R

L

P I C E R L



KING KHALID UNIVERSITY

جامعة الملك خالد

From first report to a solid lead

Initial response: gather the first facts

- 1 Interview whoever reported it
- 2 Interview IT and business staff
- 3 Review network and security logs
- 4 Determine the type of incident
- 5 Document everything you collect

A good lead is Relevant, Detailed, Actionable

Relevant

Actually tied to this incident, not just anything that looks odd.

Detailed

Has the specifics: time, addresses, who, what, where, why, how.

Actionable

You have the means to follow it up and it points somewhere.



Do not just chase malware

A common mistake is hunting only for malware. Once an attacker has valid credentials they may not need any. Chasing shiny objects wastes the investigation. Follow the leads that answer the case.

Indicators of Compromise (IoCs)

An indicator of compromise is a clue or piece of evidence of a breach. IoCs let you describe, communicate, and hunt for the artifacts of an incident.

How IoCs are written



Network IoCs

Bad IPs and domains, often as Snort rules (Chapter 3 lab).



Host IoCs

File hashes, registry keys and strings, often as Yara rules.

Most evidence is aggregated into a SIEM so investigators can organize and search it.

Everyday examples on the network



Unusual outbound traffic



Activity from strange regions



High-privilege account misuse



Excessive access to key files



Spike in database reads



Many authentication failures



Suspicious config changes



Traffic flooding one location

Validate: is the alarm real?

Before you act, judge each alert. Detection tools produce four outcomes, and two of them are dangerous.

	ALARM RAISED	NO ALARM
ATTACK	True Positive Real attack, alarm fired. The system worked.	False Negative Real attack, no alarm. The most dangerous: you are blind.
NO ATTACK	False Positive No attack, alarm fired. Wastes time and dulls attention.	True Negative No attack, no alarm. Quiet and correct.

The two that hurt



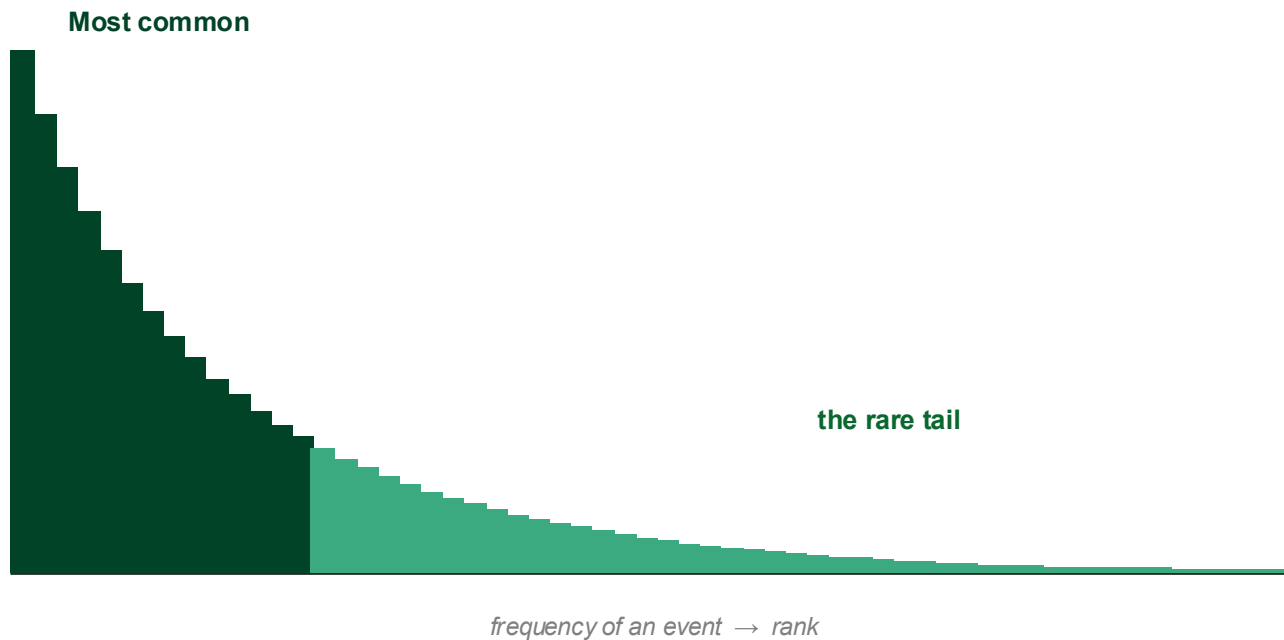
False negative is the nightmare: a real attack slips through silently. Tune detection to shrink these.



False positive is the boy who cried wolf: too many and analysts stop trusting the alerts, so a real one gets ignored.

Triage at scale: the long tail

A single host can log tens of thousands of events. You cannot read them all, so sort by frequency.



Where do attackers hide?

Often in the rare tail: the unusual, low-frequency events that blend into the noise. But not always. Some high-volume events are critical too.

4797

A query for a blank password on an account. Rare, and very suspicious. Is it head or tail, and do you chase it? (Yes.)

High-volume events: set a baseline (threshold) for the normal count, then alert only when the number exceeds it.

From ten thousand alerts to one incident

Triage at scale The analyst's real job: find the one that matters

10,000

raw alerts a day
from every sensor

A busy security team can see tens of thousands of alerts in a single day.

Correlation and triage narrow a day of alerts down to the handful, sometimes one, that are a real incident.

From a hit to a scoped incident

When a tool matches an IoC, three steps turn that raw hit into something you can act on.



Validate

Examine the match and decide if it is reliable, or just a false positive.



Categorize

Label what it is: "Backdoor Installed," "Access With Valid Credentials," "SQL Injection," "Data Theft."



Prioritize

Rank by impact on critical assets, so the team works the most damaging findings first.

Prioritize by what matters most

Rank findings against your critical assets: corporate reputation, confidential business information, personally identifiable information, and payment card data. An exposed asset reachable from the Internet is a higher priority than one locked in a controlled room. This scoping is what hands off to Containment.

STAGE 3 OF 6



Containment

Stop the incident from spreading, without tipping off the attacker too early.

Analogy: quarantine. You isolate the patient so the infection cannot reach anyone else, buying time to treat safely.

P

I

C

E

R

L

P I C E R L



KING KHALID UNIVERSITY

جامعة الملك خالد

Short-term now, long-term next



Short-term containment

Fast, immediate moves to halt the bleeding right now, even if temporary.

- ✓ Disconnect the host from the network
- ✓ Disable the compromised account
- ✓ Block the malicious IP or domain



Long-term containment

More durable barriers that let the business keep running while you prepare to remove the threat.

- ✓ Segment the network around affected systems
- ✓ Apply temporary firewall and access rules
- ✓ Rebuild clean systems ready to swap in

Contain quietly

If you move too loudly, a watching attacker may destroy evidence, trigger ransomware, or dig in deeper. Preserve evidence as you contain, that evidence powers eradication.

Contain the crown jewels first

Use the priorities from Identification. Protect the most critical, most exposed assets first: payment data, PII, confidential business information, and anything reachable from the Internet.

STAGE 4 OF 6



Eradiation

Remove the attacker and everything they left behind, completely.

Analogy: treatment. Quarantine held the infection still; now you kill the pathogen and clear it out of the body entirely.

P

I

C

E

R

L

P I C E R L



KING KHALID UNIVERSITY

جامعة الملك خالد

Take back the environment

The concrete actions that evict the attacker for good.



Remove malware

Delete backdoors, implants and every persistence mechanism found in the investigation.



Reset credentials

Change passwords and keys for every account the attacker touched, or could have.



Close the entry point

Patch the exploited vulnerability or fix the misconfiguration that let them in.



Rebuild, do not clean

For deeply compromised hosts, wipe and rebuild from a known-good image rather than trusting a cleanup.

Eradicate everything at once. If you remove nine of ten backdoors, the attacker walks straight back in through the tenth and watches you. This is why complete scoping in Identification matters: you can only eradicate what you found. Do it in one coordinated action, not piecemeal.

STAGE 5 OF 6



Recovery

Return to normal business, safely, and watch for the attacker coming back.

Analogy: rehabilitation. The infection is gone; now the patient rebuilds strength and is monitored closely for any relapse.

P

I

C

E

R

L

P I C E R L



KING KHALID UNIVERSITY

جامعة الملك خالد

Back to business, on your terms



Restore

Bring systems back from clean backups or the rebuilt images, in a planned order.



Validate

Confirm each restored system is clean and fully functional before it rejoins production.



Monitor closely

Watch the recovered environment for the attacker attempting to return.

When is it really over?

Recovery ends only when operations are normal and stay normal under close watch. A quiet week is not proof; deliberate monitoring is.

The timing trap

Rush recovery and you may restore a system that is still compromised, handing the attacker their foothold back. Patience here protects all the work of the previous stages.

DO NOT CONFUSE THEM

Contain vs Eradicate vs Recover

The three response stages students mix up the most. One clean comparison, using the same patient.



Containment

Stop the spread

The threat is still present, but boxed in so it cannot reach anything new.

Quarantine the patient



Eradication

Remove the threat

The attacker and all their tools are eliminated from the environment.

Kill the infection



Recovery

Return to normal

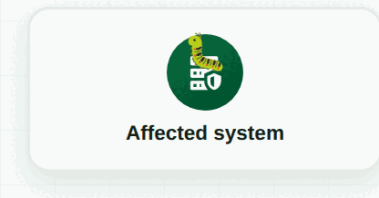
Systems are clean and back in service, watched for any sign of relapse.

Rehabilitate and monitor

The threat is present but boxed → the threat is gone → the business is running again.

Present but loud, then gone, then running

Contain, eradicate, recover Present but loud, then gone, then running again



The incident is live: the threat is active, and the service is disrupted.

Containment holds the threat, eradication removes it, and only then does recovery bring the service back.

STAGE 6 OF 6



Lessons Learned

Turn a painful incident into a permanent improvement.

Analogy: the post-outbreak review. Public-health experts study how it started so the next outbreak is smaller, or never happens.

P

I

C

E

R

L

P I C E R L



KING KHALID UNIVERSITY

جامعة الملك خالد

Ask the honest questions

The post-incident review

1

What happened, exactly?

A clear timeline from first entry to final recovery.

2

What worked, what did not?

Where the team was fast, and where it lost time.

3

How did they get in?

The root cause, so it can be closed for good.

4

What do we change?

Concrete improvements to people, process and tools.

Track through the whole case

- ✓ Evidence collected & affected systems
- ✓ Accessed or stolen data
- ✓ Significant attacker activity
- ✓ Network and host IoCs
- ✓ Compromised accounts



Close the loop

The strategic improvements from this review feed straight back into Preparation. That is what makes PICERL a cycle, not a line.

It is not done until it is written down

An incident produces a set of standard reports. Each has a purpose and a delivery target, from the reference book.

Report	Purpose	Delivery target
Case Status Report	Update stakeholders on the progress of a case	Recurring: daily or as required
Live Response Report	Findings from initial triage of a single system	Draft 1 day, final 2 days
Forensic Examination Report	Detailed findings from analysis of one item of evidence	Draft 4 days, final 6 days
Malware Analysis Report	Findings from analysis of suspected malicious software	Draft 3 days, final 5 days
Intrusion Investigation Report	Consolidates everything into a high-level executive summary	Draft 5 days, final 8 days

The Intrusion Investigation Report is the capstone: it consolidates every other report for leadership. Good documentation is what makes the lessons stick.

Chapter 2 at glance

The six stages, one line each

P

Preparation get the team, plan and tools ready in advance

I

Identification detect, validate the alert, and scope the incident

C

Containment stop the spread; short-term then long-term

E

Eradication remove the attacker and every foothold, all at once

R

Recovery restore, validate, and monitor for their return

L

Lessons Learned report it, and feed improvements back to Preparation